

Reporte Ejecutivo de Gestión de Riesgos

Clínica Privada — Dirigido al Directorio — Septiembre 2026

Resumen Ejecutivo

Como parte del proceso de fortalecimiento de la seguridad de la información, se realizó un relevamiento inicial de riesgos utilizando la herramienta SimpleRisk. El análisis identificó **7 riesgos específicos** del entorno de la clínica, vinculados al manejo de historias clínicas digitales, datos de obras sociales y facturación. De estos, **5 riesgos fueron clasificados como de nivel Alto** y 2 como nivel Medio, ninguno resultó de nivel bajo o insignificante.

El riesgo más crítico identificado corresponde al robo de dispositivos móviles sin cifrar (score 8/10), seguido por la posibilidad de un ataque de ransomware sobre el sistema de historias clínicas (score 6/10). Para los tres riesgos de mayor impacto se definieron planes de acción concretos, con responsables, plazos y presupuesto estimado asignado. Se recomienda la aprobación y asignación de recursos para su ejecución en el corto plazo.

Top 5 Riesgos por Nivel

#	Riesgo	Categoría	Score	Nivel
1	Robo de dispositivo móvil sin cifrar	Confidencialidad	8.0	Alto
2	Ransomware sobre historias clínicas	Disponibilidad	6.0	Alto
3	Filtración de historias clínicas	Confidencialidad	4.8	Alto
4	Error humano por personal no capacitado	Operativo	4.8	Alto
5	Falta de verificación del plan de continuidad	Operativo	4.8	Alto

Nota: los 2 riesgos restantes (Incumplimiento de la Ley de Protección de Datos Personales, score 3.2, y Alteración de datos en facturación, score 2.4) fueron clasificados como nivel Medio y se encuentran documentados en el registro completo de riesgos.

Estado de los Planes de Acción

Riesgo asociado	Responsable	Presupuesto	Estado
Robo de dispositivo móvil sin cifrar	Analista de Riesgos	\$0 - \$100.000	Mitigación planificada
Ransomware sobre historias clínicas	Administrador	\$0 - \$100.000	Mitigación planificada
Filtración de historias clínicas	Administrador	\$0 - \$100.000	Mitigación planificada

Los tres planes de acción se encuentran en etapa de planificación, con medidas de mitigación definidas (cifrado de dispositivos, backups y segmentación de red, y control de acceso basado en roles respectivamente). Su ejecución está sujeta a la aprobación de presupuesto por parte del Directorio.

Recomendaciones Prioritarias

- Cifrado de dispositivos móviles:** implementar cifrado de disco completo y una solución de gestión de dispositivos móviles (MDM) que permita bloqueo y borrado remoto ante pérdida o robo.
- Protección contra ransomware:** establecer backups automáticos diarios con copia offline, una solución de detección y respuesta en endpoints (EDR), y segmentación de la red que aísla el sistema de historias clínicas.
- Control de acceso a historias clínicas:** implementar control de acceso basado en roles (RBAC) bajo el principio de mínimo privilegio, junto con registro de auditoría de todos los accesos a información sensible de pacientes.

4. Capacitación del personal: establecer un programa periódico de capacitación en seguridad de la información, con énfasis en detección de phishing y manejo correcto de datos sensibles.

5. Cumplimiento normativo: contratar asesoría legal externa especializada para asegurar el cumplimiento de la Ley de Protección de Datos Personales y reducir la exposición a sanciones regulatorias.

Elaborado a partir del relevamiento de riesgos realizado en SimpleRisk. Responsable de seguridad de la información de la clínica.
Septiembre de 2026.